

20EIE554T – CYBERSECURITY IN INDUSTRIAL AUTOMATION

Dr.G.Y.Rajaa Vikhram
Assistant Professor/EIE
SRMIST

Course Learning Rationale (CLR):	The purpose of learning this course is to:
CLR-1 :	<i>Introduce the basic knowledge in industrial automation and control systems</i>
CLR-2 :	<i>Know the basic concepts of information system security for industrial control systems</i>
CLR-3 :	<i>Understand the difference between IACS and IT paradigms</i>
CLR-4 :	<i>Impart the adequate information about risk management for IACS</i>
CLR-5 :	<i>Introduce the security methodologies and approaches for IACS</i>
CLR-6 :	<i>Understand the need of cybersecurity for different industrial applications</i>

Course Outcomes (CO):	At the end of this course, learners will be able to:
CO-1 :	Describe the basic concepts of industrial automation and control systems
CO-2 :	Illustrate any application with add-on security features in industrial control systems
CO-3 :	Select the software with IT paradigms for IACS
CO-4 :	Analyze the risk management approach for IACS
CO-5 :	Examine the security methodologies for industrial systems
CO-6 :	Design cybersecurity resilient algorithm for selective applications

Risk Management for IACS
12
Risk Management
Risk Relationships
Cybersecurity Management Systems
Risk Analysis
Addressing Risk Monitoring and Improving the IACS
Tutorial: 1 – Risk metrics
Integrated Enterprise Risk Management
Guide for Applying Risk Management Framework
Insider Threat, Threat Example

Stuxnet
Tutorial: 2 – Risk assessment
Defensive Approaches
Electromagnetic Pulse
HEMP
Solar
IEMI
Protection measures, Standards – IEC & IEEE
Tutorial: 3 – Simulation and analysis

Chapter 3 explored the technological changes affecting industrial automation and control systems and their impact on securing such systems. Chapter 4 will develop the methodologies for identifying and mitigating risks in automation and control systems and provide the foundation for implementing security controls

Risk Management

Identifying and managing risks to industrial automation and control systems is a critical undertaking and a fundamental activity that is necessary to ensure the safety and security of these systems. ANSI/ISA-99.00.01-2007¹ defines risk as the “expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular consequence.” Additional, important definitions from ANSI/ISA-99.00.01-2007 are:

- Threat – Potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm
- Vulnerability – Flaw or weakness in a system’s design, implementation, or operation and management that could be exploited to violate the system’s integrity or security policy
- Residual risk – Remaining risk after the security controls or countermeasures have been applied
- Risk assessment – Process that systematically identifies potential vulnerabilities to valuable system resources and threats to those resources, quantifies loss exposures and consequences based on

probability of occurrence, and (optionally) recommends how to allocate resources to countermeasures to minimize total exposure

- Risk management – Process of identifying and applying countermeasures commensurate with the value of the assets protected based on a risk assessment

To obtain another perspective, NIST Special Publication 800-39² defines risk as “a measure of the extent to which an entity is threatened by a potential circumstance or event and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.” The other NIST SP 800-39 corresponding definitions are:

- Threat – Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the nation through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service
- Vulnerability – Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source

- Risk assessment – The process of identifying risks to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the nation, resulting from the operation of an information system
- Risk management – The program and supporting processes to manage information security risk to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the nation, and includes: (i) establishing the context for risk-related activities; (ii) assessing risk; (iii) responding to risk once determined; and (iv) monitoring risk over time. Part of risk management incorporates threat and vulnerability analyses, and considers mitigations provided by security controls planned or in place.

The *Common Criteria*³ document describes the relationships among threats, risk, countermeasures, and assets to be protected, as shown in [Figure 5-1](#).

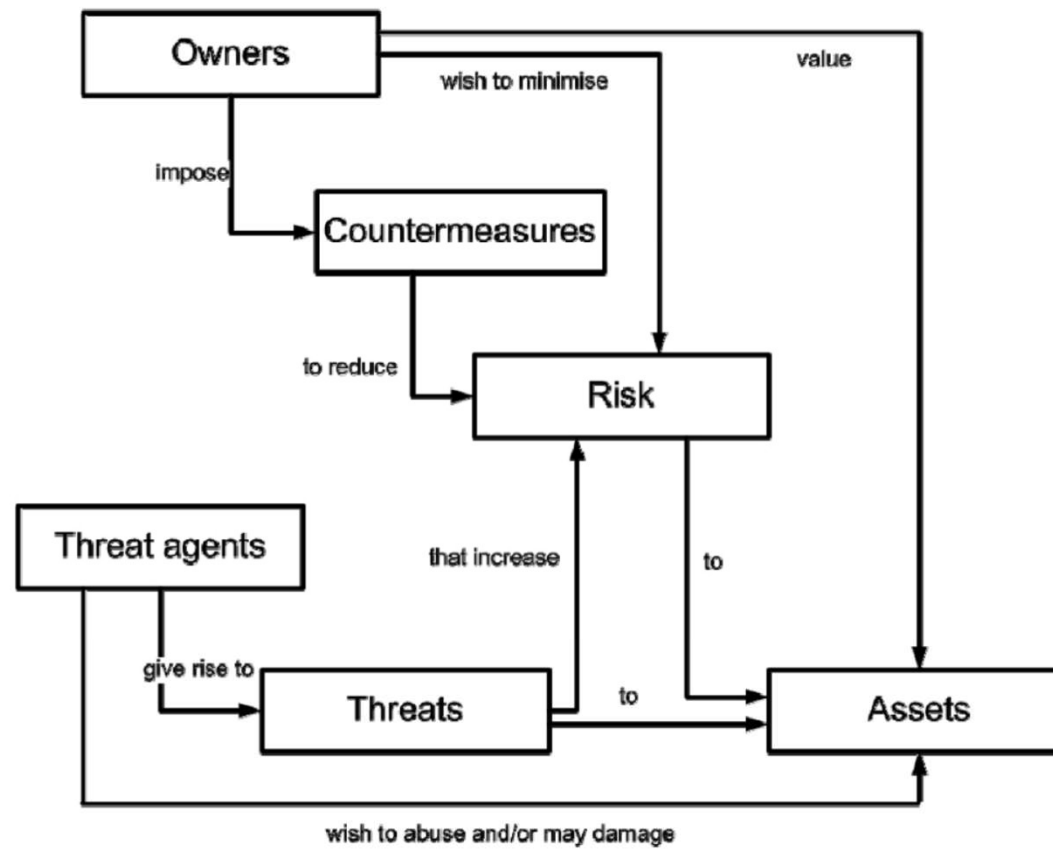


Figure 5-1. Risk relationships

[Source: *Common Criteria for Information Technology Security Evaluation Part 1: Introduction and General Model*, Version 3.1, Revision 3, July 2009.]

Assets can include physical elements, such as computer hardware, control systems, or specialized equipment, in addition to intangible assets, such as intellectual property, compliance information, or process expertise. Another important category of asset is the individual or professional who professes unique knowledge and skills that, for example, are critical in the operation and maintenance of industrial automation and control systems.

Three valuable approaches to risk management are presented in ANSI/ISA-99.02.01-2009, NIST SP 800-39, and NIST SP 800-37, which will be reviewed in the following sections.

ANSI/ISA-99.02.01 Cybersecurity Management System

To determine and mitigate risk, ANSI/ISA-99.02.01-2009⁴ defines a cybersecurity management system (CSMS) as shown in [Figure 5-2](#).

The CSMS comprises the three main categories of risk analysis, addressing the risk, and monitoring and improving the CSMS.

Risk Analysis

In the risk analysis category of the CSMS, a business rationale is established, and risk identification, classification, and assessment are conducted. The business rationale includes the following:

- Establishing a basis for securing the industrial automation and control system
- Obtaining management support for securing the automation and control system
- Identifying and understanding the consequences of a successful attack on the automation and control system

Risk identification, classification, and assessment include ascertaining and prioritizing the risks to industrial automation and control systems and estimating the likelihood and impact of those risks. Specifically, this area of the CSMS includes the following activities:

- Select a risk assessment methodology
- Conduct a high-level risk assessment
- Identify the industrial automation and control systems to be addressed
- Develop simple network diagrams
- Prioritize the systems for mitigation
- Perform a detailed vulnerability assessment
- Conduct a detailed risk assessment
- Maintain vulnerability assessment records

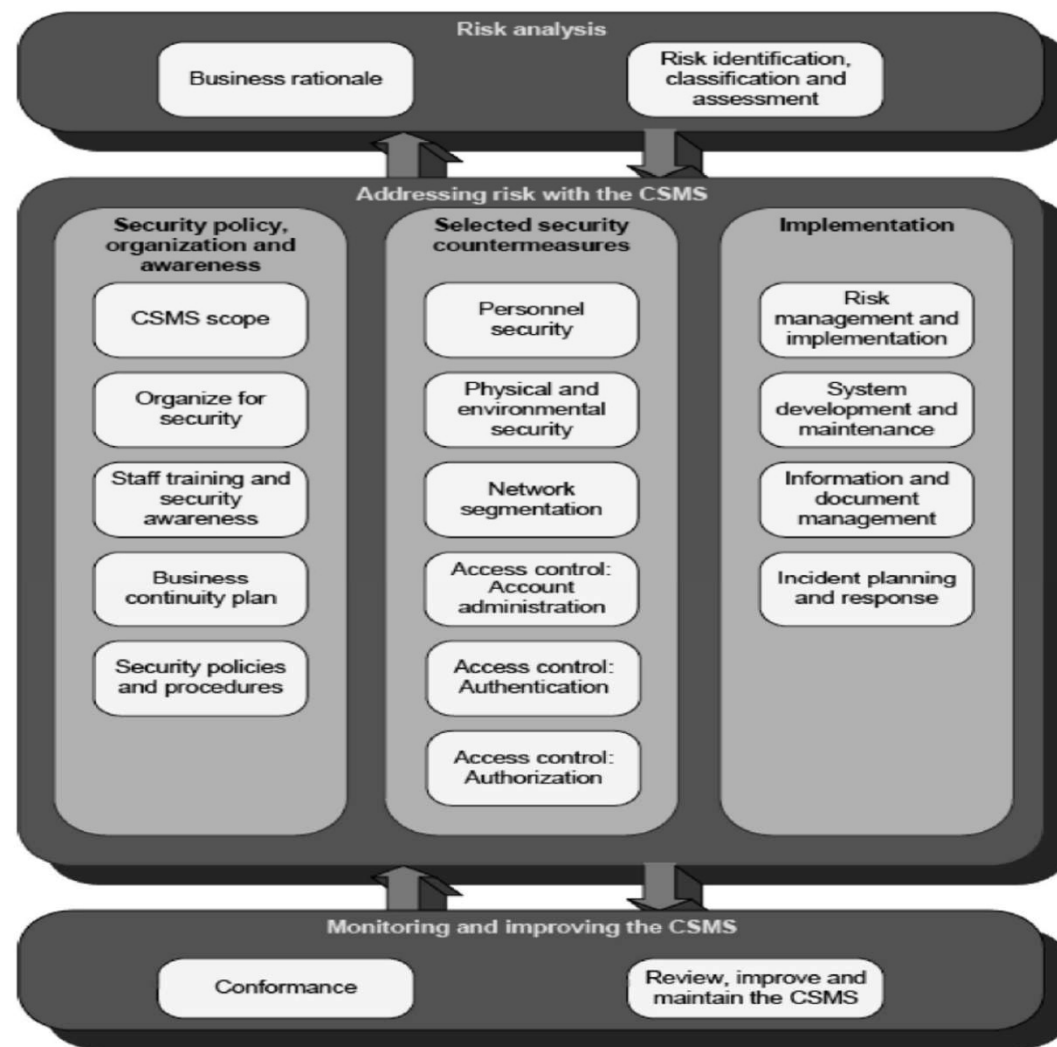


Figure 5-2. Cybersecurity management system (CSMS)
[Source: ANSI/ISA-99.02.01-2009 n 3.1, Revision 3, July 2009.]

Addressing Risk

The next major CSMS category, addressing risk, comprises the following areas:

- Security policy, organization and awareness
- Selected security countermeasures
- Implementation

As shown in [Figure 5-2](#), security policy, organization and awareness includes documenting the elements that fall within the scope of the CSMS and assigning responsibilities for overall cybersecurity. In addition, this category incorporates providing staff and contractor personnel with adequate training and information to be aware of threats and weaknesses, and to have the ability to take remedial action if necessary. Further activities include developing a business continuity plan for reestablishing essential business operations upon the occurrence of an event that causes a business disruption and developing security policies and procedures applicable to automation and control systems and compatible with general organizational policies.

The second group under addressing risk with the CSMS is selected security countermeasures. The activities in this group include personnel security, physical and environmental security, network segmentation, and access control of account administration, authentication, and authorization.

Personnel security is concerned with evaluating personnel to ensure they exhibit appropriate behaviors and will be able to preserve the security of the automation and control systems.

Physical and environmental security are focused on protecting industrial automation and control systems from physical threats and malfunctions in environmental systems, such as power supplies and temperature controls.

In *network segmentation*, networks are subdivided into zones that have similar security requirements and characteristics, and they are separated by protective devices to screen traffic from one network segment to another.

Access control determines which entities can have access to resources; it is broken down into *account administration*, *authentication*, and *authorization*. In account administration, access to accounts is controlled and limited to entities that have privileges associated with those accounts. Authentication requires strong verification of a claimed user's identity prior to granting access to specific resources, and authorization provides access privileges to specific accounts upon successful authentication.

The third CSMS group under addressing risk is implementation, which comprises risk management and implementation, system development and maintenance, information and document management, and incident planning and response.

Risk management and implementation consist of identifying and putting in place countermeasures that are technically and financially warranted to address determined risks. *System development and maintenance* emphasizes the inclusion of cybersecurity considerations throughout the system development life cycle, including in the maintenance phase when system changes might frequently occur. *Information and document management* is concerned with applying information and document management policies in order to protect sensitive information from unauthorized disclosure. The last item in this group, *incident planning and response*, focuses on having plans and procedures in place to effectively respond to incidents, including reporting and investigative and follow-up activities.

Monitoring and Improving the CSMS

The last category of the CSMS, monitoring and improving the CSMS, consists of the elements of (a) conformance and (b) review, improve, and maintain the CSMS. *Conformance* verifies that an automation and control system is compliant with appropriate policies, procedures, and regulations. *Review, improve, and maintain the CSMS* requires continuous supervision of the CSMS to make sure responses to changes or threats are incorporated into the CSMS.

An additional benefit of implementing a CSMS, as cited in ANSI/ISA-99.00.01-2007⁵, is maintaining the security level of industrial automation and control systems over time. Many security efforts are undertaken on a project basis, and system security deteriorates over time with the evolution of new threats and changes in the system architecture. [Figure 5-3](#) illustrates the relative security levels of project-oriented industrial automation and control systems (IACS) and CSMS-based IACS.

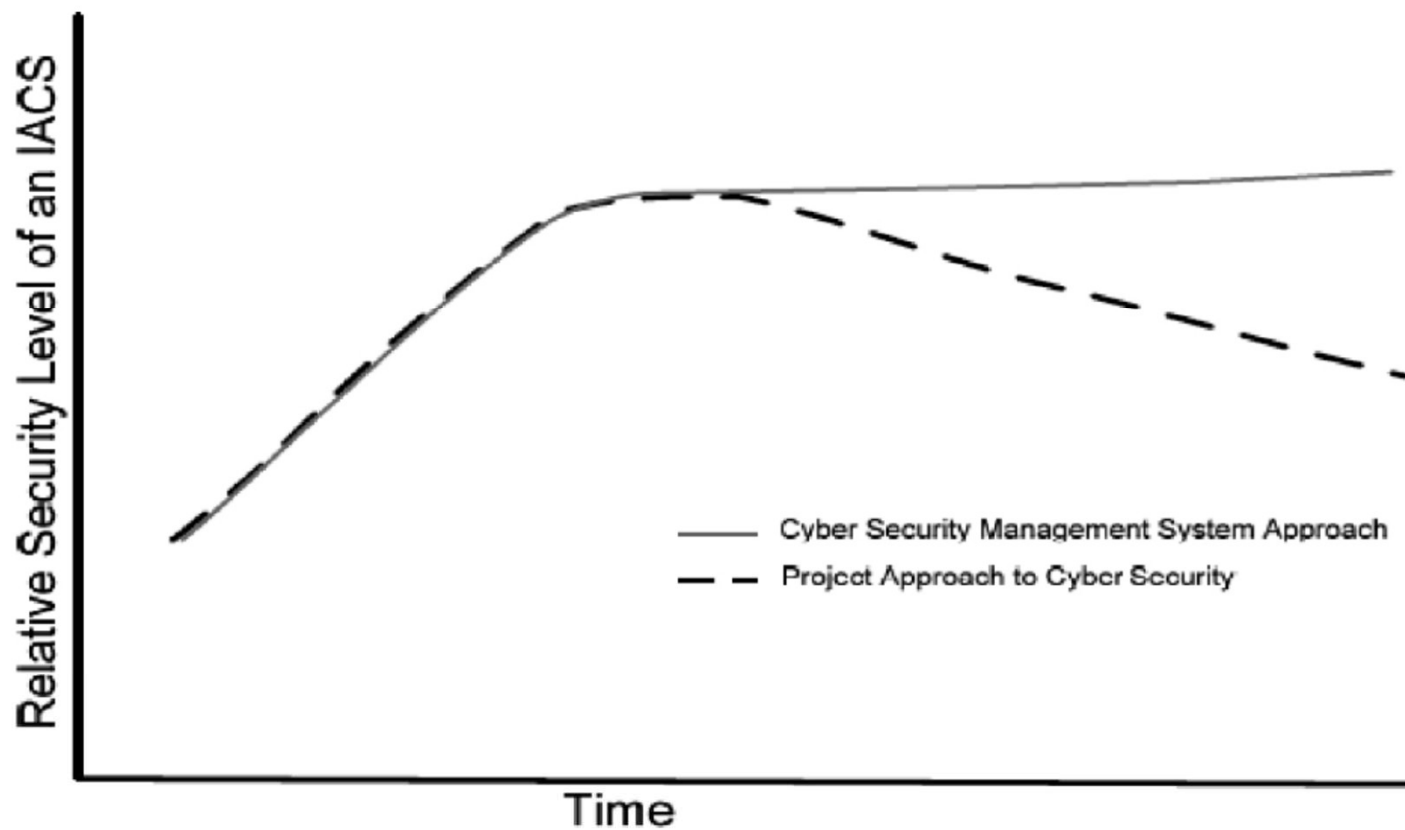


Figure 5-3. Relative cybersecurity over time

[Source: ANSI/ISA-99.00.01-2007, October 2007.]

NIST Special Publication 800-39 Integrated Enterprise Risk Management

NIST SP 800-39⁶, *Managing Information Security Risk: Organization, Mission, and Information System View*, March 2011 replaces NIST SP 800-30⁷, *Risk Management Guide for Information Technology Systems*, which, at the time of writing, is being revised to provide guidance on risk assessment as a supporting document to Special Publication 800-39. NIST SP 800-39 views risk management as:

A comprehensive process that requires organizations to: (i) frame risk (i.e., establish the context for risk-based decisions); (ii) assess risk; (iii) respond to risk once determined; and (iv) monitor risk on an ongoing basis, using effective organizational communications and a feedback loop for continuous improvement in the risk-related activities of organizations.

toward these ends, it takes a global view of risk management and does not limit the risk management process to elements of information systems or automation and control systems alone. The approach views risk management as a hierarchical structure that has to involve the organization's mission and business goals, the organization's business processes, and the system development life cycle of information and automation system components. The document formalizes these subject areas into the following three tiers:

- Tier 1 – Organization: Establishes and implements governance structures consistent with organizational mission and goals
- Tier 2 – Mission/Business Processes: Designs, develops, and implements mission/business processes to support the mission defined in Tier 1

- Tier 3 – Information Systems: Integrates risk management activities into the system development life cycle (SDLC) of organizational information systems and addresses the resilience of organizational information systems. Tier 3 risk is addressed through NIST SP 800-53, which incorporates security controls for automation systems. These controls will be discussed in detail in [Chapter 6](#).

This multitiered approach is summarized in [Figure 5-4](#).

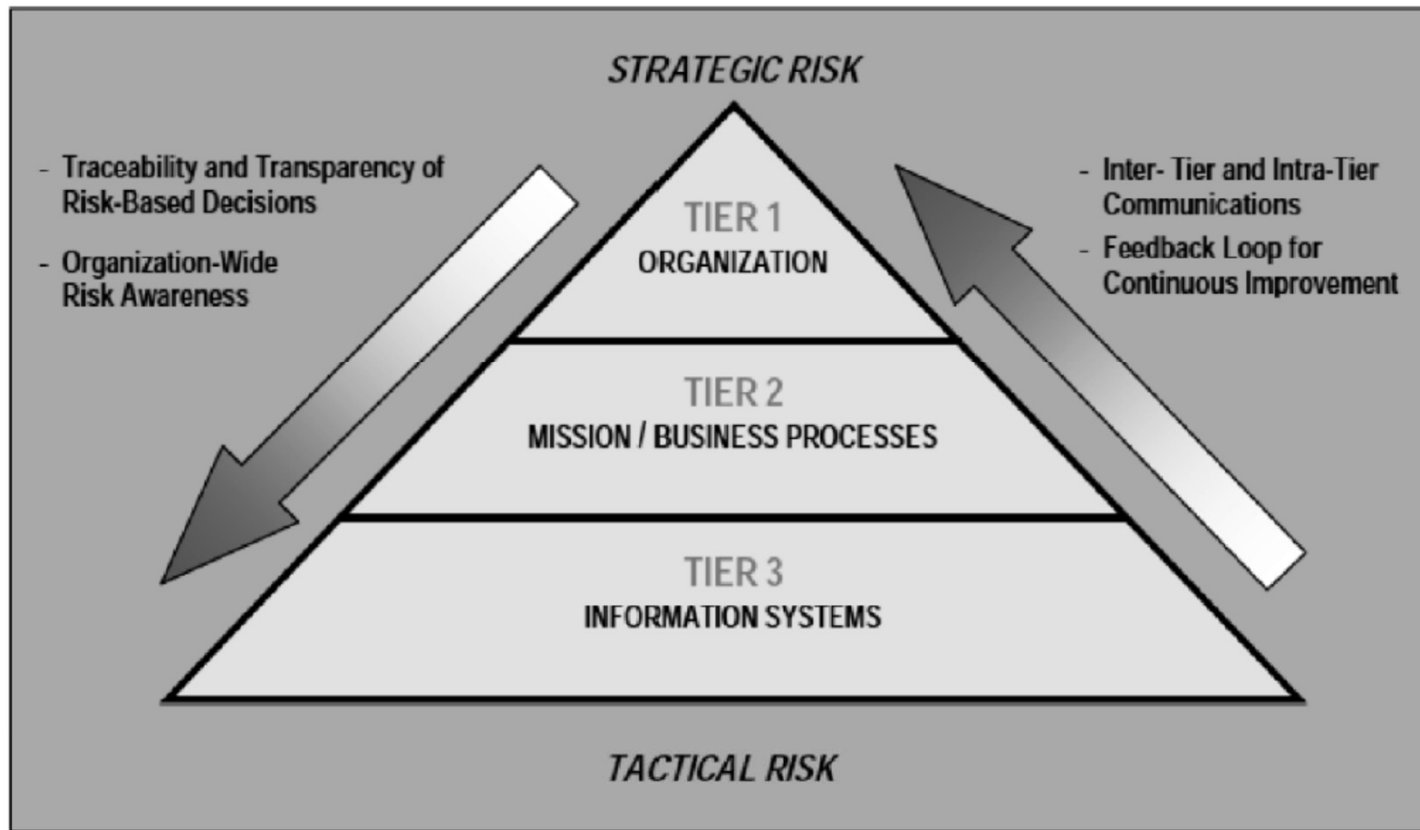


Figure 5-4. Multitiered risk management

[Source: NIST SP 800-39, March 2011.]

In [Figure 5-4](#), Tier 1 risk management prioritizes mission/business functions, evaluates strategic and funding alternatives, provides risk management guidance to authorizing officials, and establishes the order of recovery of critical information systems.

Tier 2 execution follows from the output of Tier 1 activities. Tier 2 functions include defining the necessary and critical mission/business processes of the organization, prioritizing these functions based on organizational objectives, and determining the specific types of information necessary to carry out the organization's mission/business processes. An important concept in Tier 2 is the information security architecture, which is that part of the enterprise architecture that is concerned with the robustness of the information or automation and control system and its resistance to attacks. The information security architecture should incorporate the best elements of defense in depth and defense in breadth and is illustrated in [Figure 5-5](#). Defense in breadth is a planned, systematic set of multidisciplinary activities that seek to mitigate risk at every stage of the system development life cycle.

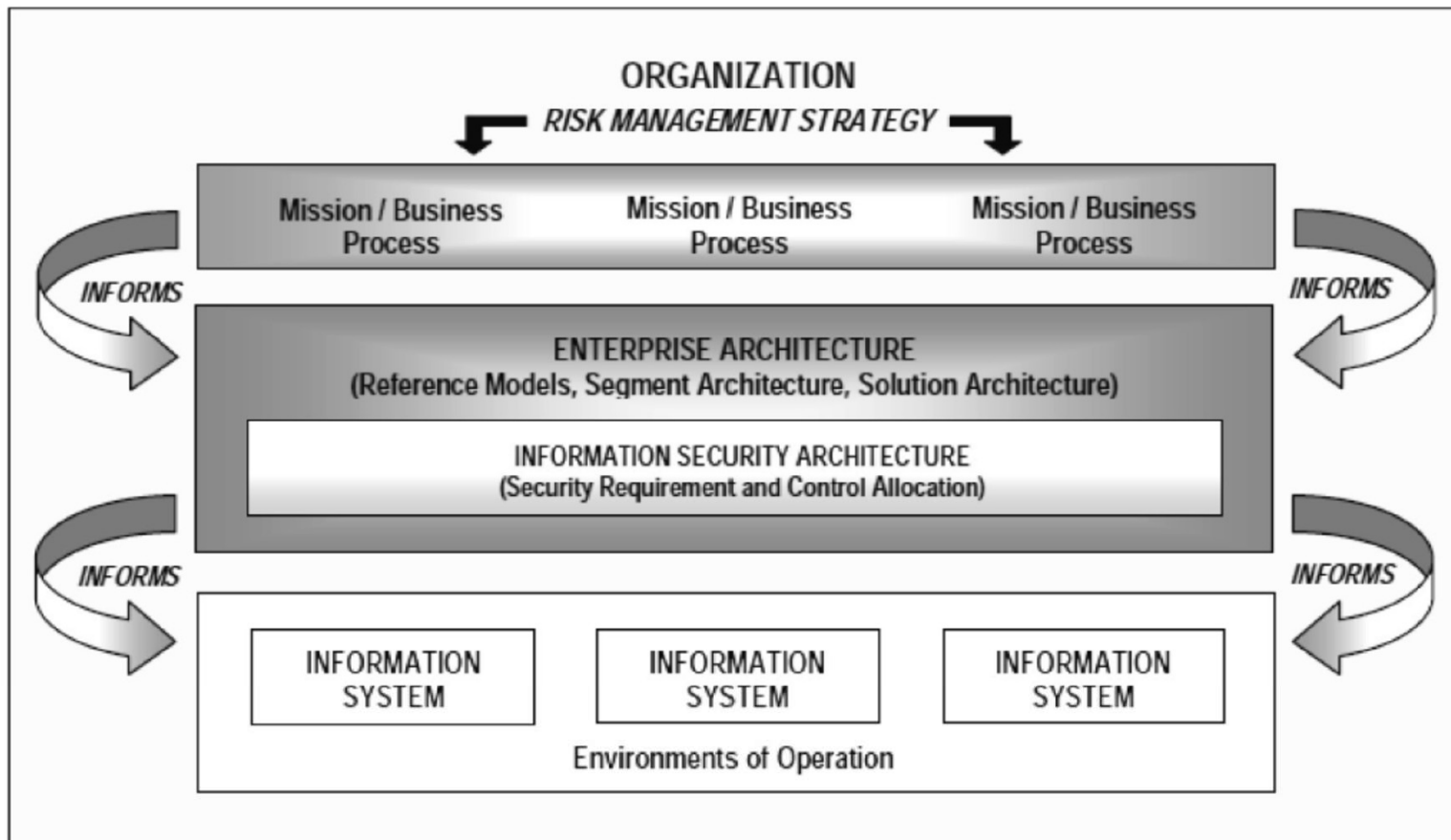


Figure 5-5. Integration of information security requirements

[Source: NIST SP 800-39, March 2011.]

Figure 5-5 shows that risk management can be addressed as an element of the enterprise architecture. The process is summarized in NIST SP 800-39 as:

- Developing a segment architecture linked to the strategic goals and objectives of organizations, defined missions/business functions, and associated mission/business processes
- Identifying where effective risk response is a critical element in the success of organizational missions and business functions
- Defining the appropriate, architectural-level information security requirements within organization-defined segments based on the organization's risk management strategy

- Incorporating an information security architecture that implements architectural-level information security requirements
- Translating the information security requirements from the segment architecture into specific security controls for information systems/environments of operation as part of the solution architecture
- Allocating management, operational, and technical security controls to information systems and environments of operation as defined by the information security architecture
- Documenting risk management decisions at all levels of the enterprise architecture

Tier 3 focuses on information systems or automation and control systems and follows from the information passed down from tiers 1 and 2. Some tier 3 functions include categorizing organizational information systems, properly allocating security controls to those systems to support the organization's mission/business processes, and managing and monitoring security controls on an ongoing basis. Tier 3 addresses risk management in the following system development life cycle phases, which includes that of industrial automation and control systems:

1. Initiation
2. Development/acquisition
3. Implementation
4. Operations/maintenance
5. Disposal

As defined above, NIST SP 800-39 defines the components of risk management as risk framing, risk assessment, risk response, and risk monitoring. The relationship of these components to the three tiers is given in [Figure 5-6](#).

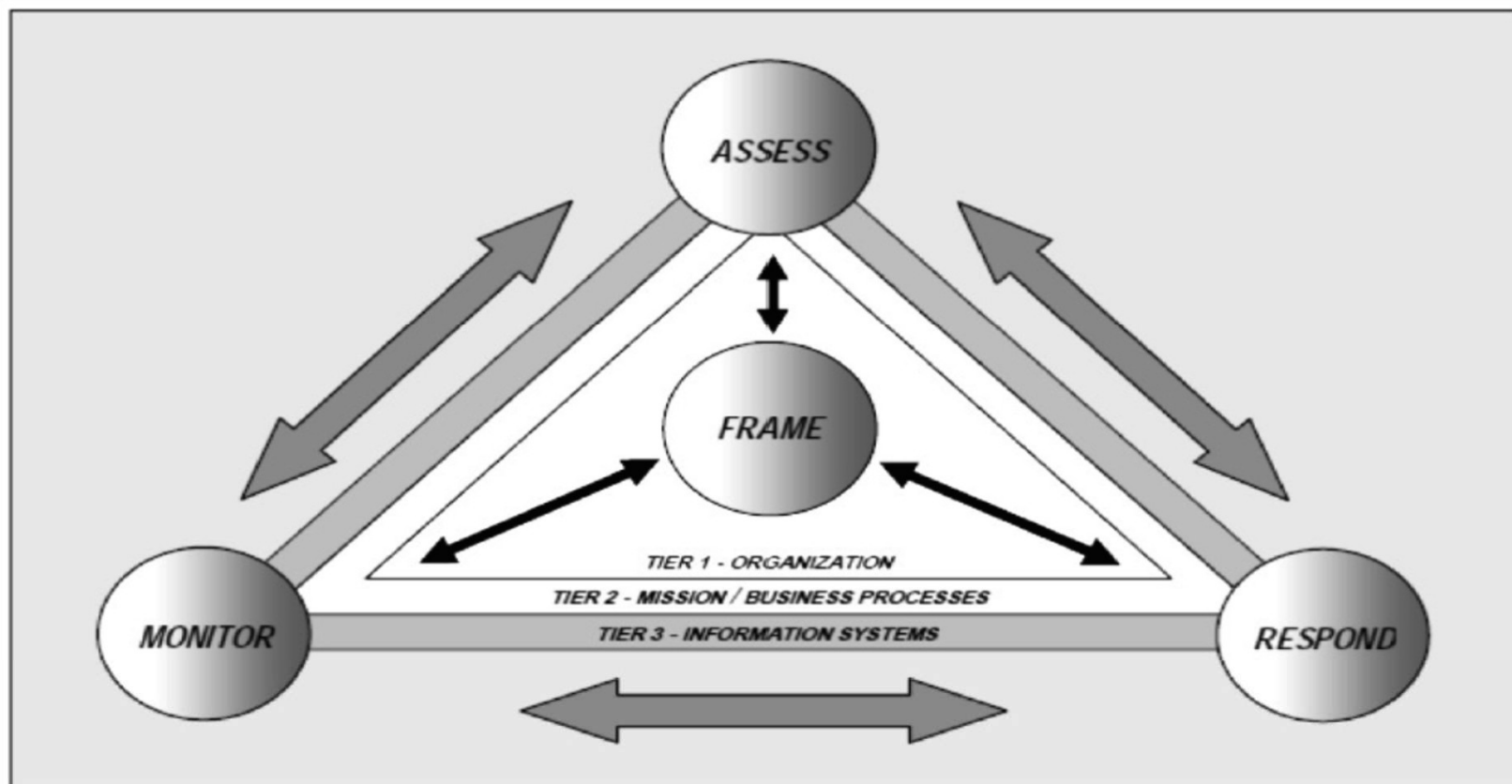


Figure 5-6. Risk management and the tiers

[Source: NIST SP 800-39, March 2011.]

Risk framing (Figure 5-6) includes the following tasks:

1. Making assumptions about threats, vulnerabilities, consequences/impact, and likelihood of occurrence
2. Determining restraints on risk assessment, response, and monitoring
3. Determining risk tolerance levels
4. Identifying priorities and trade-offs

Risk assessment includes the following activities:

1. Identifying threats to the organization
2. Identifying vulnerabilities
3. Determining the impact of threats realized
4. Determining the likelihood of harm occurring

Risk response includes:

1. Developing alternative courses of action
2. Evaluating these alternative courses of action
3. Selecting the best courses of action
4. Implementing selected responses

Risk monitoring is concerned with:

1. Confirming that risk response measures have been implemented
2. Evaluating the effectiveness of implemented risk response measures
3. Determining changes to organizational information systems that would affect risk

NIST SP 800-37 Guide for Applying the Risk Management Framework to Federal Information Systems

NIST SP 800-37⁸ provides additional risk management guidance through the Risk Management Framework (RMF), which “provides a disciplined and structured process that integrates information security and risk management activities into the system development life cycle. The RMF operates primarily at Tier 3 in the risk management hierarchy, but can also have interactions at Tiers 1 and 2.” The RMF comprises the following elements:

- **Categorize** the information system and the information processed, stored, and transmitted by that system based on an impact analysis.
- **Select** an initial set of baseline security controls for the information system based on the security categorization, tailoring and supplementing the security control baseline as needed based on an organizational assessment of risk and on local conditions.

- **Implement** the security controls and describe how the controls are employed within the information system and its environment of operation.
- **Assess** the security controls using appropriate assessment procedures to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system.
- **Authorize** information system operation based on a determination of the risk to organizational operations and assets, individuals, other organizations, and the nation, resulting from the operation of the information system and the decision that this risk is acceptable.
- **Monitor** the security controls in the information system on an ongoing basis, including assessing control effectiveness, documenting changes to the system or its environment of operation, conducting security impact analyses of the associated changes, and reporting the security state of the system to designated organizational officials.

The Insider Threat

As discussed in the previous ANSI and NIST documents in this chapter, one of the major efforts in risk management is to determine the threats to an industrial automation and control system. Most conventional threats have been reviewed extensively in many books and papers. One important conventional threat that deserves attention is the insider attack. This type of attack, from individuals within an organization, is of particular concern because it can bypass many institutional safeguards. Some of the common characteristics of insider attacks are:

- Many attacks are conducted by a disgruntled insider.
- In common with other types of attacks, insider attacks make systems unavailable and can result in serious losses and harm to reputation.
- Insiders who initiate attacks against computers usually give some indication of dissatisfaction beforehand.
- Many insider attacks are conducted remotely.
- Most inside attackers have privileged access to computer systems.
- Many insider attacks are planned in advance.

Threat Examples Worthy of Note

A number of threats are so potentially harmful that it is important to look at them as learning examples and as a means to understand how to counteract threats in general.

There are two threats to industrial automation and control systems that are out of the ordinary and worthy of detailed exploration. These threats are Stuxnet and electromagnetic pulse (EMP) emanations.

Stuxnet and Defensive Approaches

Stuxnet is a worm that was designed to change control outputs on specific PLCs and conceal its existence from control room observers. It is of such complexity that it is probably the product of a team of programmers working many months to develop, debug, and test. The sophistication of Stuxnet leads many to believe it is the product of one or more nations working together. Some of the salient characteristics of Stuxnet are:

- Discovered in June 2010, but suspected to have been spread many months before
- Infects Windows PCs
- Modifies WinCC databases, which provide process visualization HMI functions
- Attacks both networked and non-networked PCs
- Accomplishes infection through USB flash drives
- Uses zero-day exploits, which take advantage of previously unidentified vulnerabilities

- Installs device drivers, using valid, digital certificates “appropriated” from trusted sources
- Specifically targets Siemens SIMATIC STEP 7 PLCs through a Windows PC
- Manipulates output bits on PLCs that control processes
- Focuses, it is speculated, on disrupting the operation of centrifuges at the Iranian Natanz uranium enrichment facility by changing values on turbine controls and frequency converters
- Receives updates through communications with servers in Denmark and Malaysia and through peer-to-peer communications
- Conceals its actions from the network control center so that operators do not have any indication of improper operations or malfunctions

From the information known about Stuxnet, it is not a great leap to imagine it being targeted at elements of a nation's critical infrastructure, particularly the Smart Grid, in addition to refineries, chemical plants, pipelines, and so on.

Preventive measures against Stuxnet include scanning and using firewalls on both incoming and outgoing connections to control the spread of the worm to other systems. However, because Stuxnet launched a zero-day attack, which exploited heretofore unknown Microsoft vulnerabilities, it will be difficult to detect other possible intrusions taking advantage of future, unknown vulnerabilities.

A promising countermeasure against worms, such as Stuxnet, is the use of whitelisting of valid, executable code. In whitelisting, software that is "clean" and not compromised is placed on a "whitelist" and only that code can be run on the control system. The code is validated by generating a cryptographic hash or message digest from the code, and this value is stored for future reference. Then, whenever a program is scheduled for execution, its hash is generated and compared against the hash of the original "clean" program. If the hashes are identical, the code has not been modified and is permitted to run. If the hashes are different or there is no such hash on the valid hash list, then the code is marked as malware and is not executed.

Whitelisting is, thus, effective against “zero-day” attacks in that this countermeasure is not dependent on knowing the signature of malicious code in advance.

One problem with whitelisting is that, in an environment where there are frequent changes and patches to software, the whitelist has to be constantly updated to keep current. Fortunately, most automation and control systems do not require as many updates as IT systems.

Another concept related to whitelisting is intrusion tolerance. Intrusion tolerance assumes that malicious attacks will succeed in penetrating a computing system and performs actions to negate their effects. A good example of intrusion tolerance is the Self Cleansing Intrusion Tolerance (SCIT)⁹ system developed by Professor Arun Sood of George Mason University, colleagues, and students.

SCIT counters malware by repeatedly booting up a new, clean version of the operating system at predefined and selectable intervals. SCIT operates in the following manner:

1. When a server is booted, the SCIT control software launches a pristine, malware-free copy of the server's operating system into a virtual machine.
2. Following a random time period when the operating system has been exposed to the Internet, the virtual server is taken off-line and replaced by a clean, new, virtual server.
3. The removed server is then cleaned and loaded with a new, clean version of the operating system and placed in the queue for subsequent activation.

SCIT assumes that attacks are potentially always in progress and does not attempt to detect intrusions but continuously goes about replacing and cleaning the potentially corrupted software. [Figure 5-7](#) illustrates the on-line servers and the servers being cleaned. There is a continuous decommissioning and commissioning of servers at approximately 30-second intervals.

An SCIT virtual machine can be in one of the following four states:

1. Active state – The virtual machine is running on-line and accepts and processes requests.
2. Grace period state – The virtual machine processes existing requests but does not service any new requests.
3. Inactive state – The virtual machine is not performing any tasks and is off-line for cleaning.
4. Live spare state – The virtual machine has been cleaned and is ready to return to on-line processing.

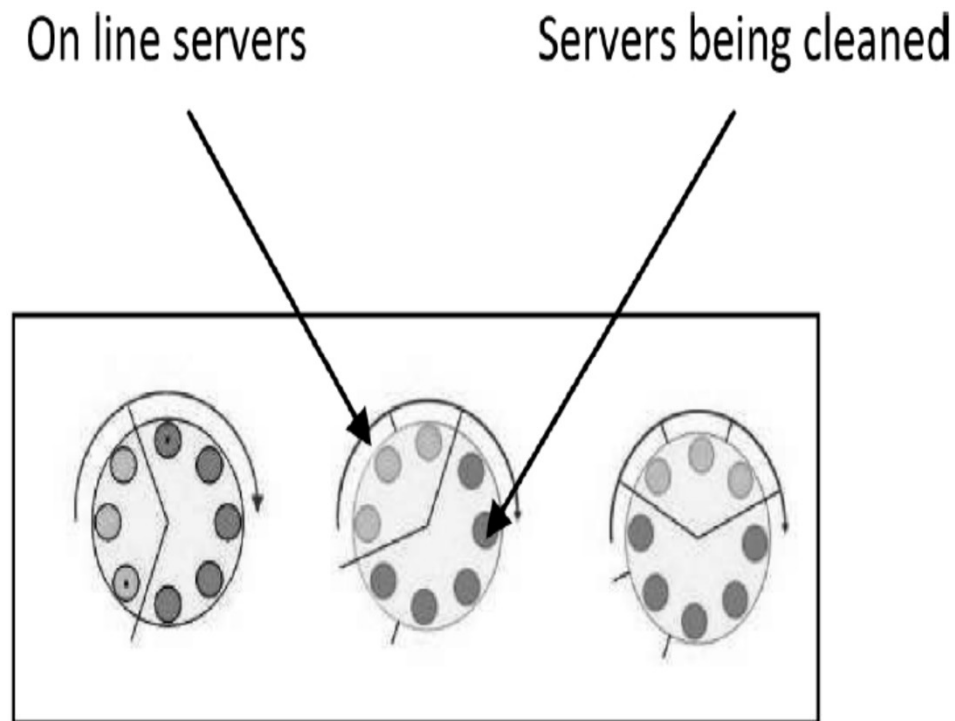


Figure 5-7. SCIT decommissioning and commissioning of virtual servers

[Source: *Securing Web Servers Using Self Cleansing Intrusion Tolerance (SCIT)*, Proceedings of the Second International Conference on Dependability, June 2009.]

An example application of SCIT to industrial automation and control systems might be in some of the domains of the Smart Grid, for example, the operations, service provider, or customer domain. In the customer domain, SCIT could be used in the Advanced Metering Infrastructure (AMI). SCIT would serve to prevent intrusions into the Smart Grid infrastructure through potentially vulnerable interfaces, such as in smart meters and data collection points.

Yet another, albeit more restrictive approach to protecting industrial automation and control systems is to limit the transmission of data to only one direction, from the automation and control system to the higher corporate IT system. In this manner, no malicious code can be sent from the IT-connected

Internet to control systems. This method is known as a data diode in that it allows data to be transmitted in one direction only. The unilateral transmission of messages has obvious advantages, but its use is limited to architectures that do not rely on two-way transmission of data and commands. A number of data diode products are available that support a variety of automation and control system protocols.

Worms, such as Stuxnet, raise the specter of cyberwarfare among nations. This situation raises a number of difficult questions for dealing with such attacks. For example:

- Does the military have a role in defending against cyberattacks?
- How does one determine if the attack was initiated by a state or by rogue individuals operating in a state?
- How may the origin of a cyberattack be determined and with what accuracy?
- Is international law up-to-date with the technical progress of digital systems?
- Should preemptive attacks be used?
- Should the military role be offensive, defensive, or both?
- What part does international law play in cyberwarfare?

Electromagnetic Pulse

A threat not commonly planned for in industrial automation and control systems is electromagnetic pulse (EMP) interference. William Radasky, in a paper titled “High Power Electromagnetic (HPEM) Threats to the Smart Grid¹⁰,” analyzes this threat and its potential effects on power distribution systems. Because the Smart Grid depends more on electronic communication and processing resources, it can be more vulnerable to EMP than older power systems.

EMP can originate from the following three primary sources:

- A high-altitude nuclear detonation in space at heights above 30 km – High Altitude EMP (HEMP)
- Solar activity – Geomagnetic storms
- Electromagnetic emanations created by terrorists or criminal elements – Intentional Electromagnetic Interference (IEMI)

HEMP

As discussed in the “High Power Electromagnetic (HPEM) Threats to the Smart Grid” paper, HEMP has the following three time-based components:

- Early-time (E1) within 10 ns of the burst – Produces an electric field pulse in the range of 2.5 to 25 ns at levels of approximately 50 kV/m that travels at the velocity of light. This field can penetrate substation walls and induce voltages of around 20 kV into substation control circuits.
- Intermediate-time (E2) between 1 microsecond and 1 second after the burst – Produces field levels reaching 100 V/m
- Late-time (E3) between 1 second and several hundred seconds after the burst – Produces field levels reaching 40 V/km

It is estimated that the environments at times E1 and E3 have the potential of causing the most damage to electric power systems because of the combination of high coupling efficiency to control lines and the peak field level values. Also, microwave towers with their extensive cabling are ideal induction targets for E1 HEMP, providing a path to sensitive communications and control equipment. E1 HEMP is also a serious threat to SCADA systems in power generation facilities, including controls and communications for wind turbines, solar cells, and other variable generation sources. E3 HEMP pulses are typically on the order of 1 second to several hundred seconds and can generate fields that are capable of coupling 4000 V between transformer grounded neutrals and inducing currents on the order of 800 A. This activity can also generate harmonics that would propagate through the power system and cause large amounts of damage, particularly to the equipment of the Smart Grid.

Solar

Regarding solar activity, extreme geomagnetic storms on the sun can generate electric fields in the range of 20 V/km and cause distortions in the Earth's surface geomagnetic field. Such changes cause fluctuations in the earth's electric field; these fluctuations induce currents in the neutral lines and generate damaging harmonics in the power grids, similar to E3 HEMP. On August 6, 2011, U.S. government scientists warned users of satellite, telecommunications, and electric equipment to prepare for possible disruptions occurring during the week. "The magnetic storm that is soon to develop probably will be in the moderate to strong level," said Joseph Kunches, a space weather scientist at the Space Weather Prediction Center, a division of the U.S. National Oceanic and Atmospheric Administration (NOAA). He stated that solar storms occurring during this period could affect communications and global positioning system (GPS) satellites and might even produce an aurora visible as far south as Minnesota and Wisconsin. Tom Bogdan, Director of the Center, said the sun is going from a quiet period into a busier cycle for solar flares, and an increase in the number of such blasts is expected over the next three to five years. Similarly, the Sunday, August 7, edition of *The New York Times*, in an article titled "Effects of Solar Flares Arriving on Earth," stated that "operators of electrical grids are working to avoid outages, but the National Oceanic and Atmospheric Administration says some satellite communications and global positioning systems could face problems."

IEMI

IEMI is categorized into wideband and narrowband fields above 100 MHz with peaks at 10 kV/m or higher. IEMI poses significant threats to substation electronics, smart meters, communications systems, and so on.

Protection

Protective measures cited by Radasky¹¹ against EMP threats include placing control rooms and electronics in basements surrounded by soil, which offers some protection against EMP fields. Cabling should also be placed in the center of the building, if possible, to minimize EMP inductive fields.

- EM shielding should be applied to protect vulnerable electronics in control centers and power generating facilities.
- Fiber optic cabling can minimize coupling if properly applied.
- High-frequency grounding with filters and surge arrestors can be used to protect sensors, smart meters, communications systems, and so on.

Protection against EMP should take into account the following field characteristics:

- High-frequency pulses can induce currents in floating wires.
- High-frequency pulses can penetrate through windows and gaps in metal shields.
- High-frequency fields do not have high energy content and therefore, surge protection devices can be effective.
- Low-frequency electromagnetic fields, such as those generated by E3 HEMP and extreme geomagnetic storms, can be mitigated by incorporating good grounding techniques and by using capacitors on neutral connections to provide a fast bypass mechanism for surges.

Some organizations and standards that address EMP threats include:

- IEC SC 77C - *EMC: High Power Transient Phenomena and Smart Grid Implications*
- IEEE P1642 The IEEE EMC Society/TC-5 (High-power EM), *Recommended Practice for Protecting Public Accessible Computer Systems*
- IEEE/ANSI C62.41 *Product Application Location, Test Methods, Guide to Using the Standard*
- MIL-STD 188-125-1 *HEMP Hardening (Fixed Facilities)*
- MIL-STD 188-125-2 *HEMP Hardening (Transportable Systems)*
- MIL-STD 202 *Environmental Requirements Component Level*
- MIL-STD 461 *EMI Requirements (Subsystems)*

- MIL-STD 464 *EMI Requirements (Systems)*
- MIL-STD 810 *Environmental Requirements Box Level*
- RTCA DO-160F *Aircraft Protection*
- The International Council on Large Electric Systems WG C4.206 *Protection of the High Voltage Power Network Control Electronics against Intentional Electromagnetic Interference (IEMI)*
- The International Telecommunications Union (ITU-T) Study Group 5
- UL1449 *Safety Standards for Low Voltage Surge Protective Devices (Steering Committee)*

Summary

Chapter 5 discussed and summarized three important risk management methodologies and their application to industrial automation and control systems. A key component of risk management is risk mitigation, and, in developing this topic, this chapter provides a basis for Chapter 6. In Chapter 6, approaches and means to secure industrial automation and control systems are developed along with guidelines for maintaining that security.